

Auto-Pwn or Auto-Fail

AI in Penetration Testing: The truth about AI in Offensive Security

Dumisani Masimini | Pentest People

```
$ ai-pentest --target all  
> scanning...  
> 247 findings  
> validating...  
> 14 confirmed  
> report.pdf ✓  
  
> but did you  
   understand it?
```

Why This Talk?

AI is Everywhere

Every tool, every vendor, every conference is talking about AI in offensive security.

The Big Question

"Can AI do the job for me?" — Clients ask it. Juniors ask it. You've probably asked it.

The Real Risk

It isn't being replaced by AI. It's becoming careless because of it.

This is a reality check for pentesters.

The Core Question

**Are you using AI as a tool...
or letting it think for you?**

Tool → Auto-Pwn

Dependent → Auto-Fail

What We'll Cover

01

AI Hype vs Reality

02

Where AI Actually Helps (Auto-Pwn)

03

Where AI Fails (Auto-Fail)

04

Real Risks in Pentesting Workflows

05

Using AI Without Losing Credibility

06

What Makes a Strong Pentester Now

The Industry Right Now

"AI will replace pentesters"

"Just prompt your way to exploitation"

"Fully automated pentesting is here"

Sounds great... until you try it on a real engagement.

What AI Is Actually Good At

Generate Payload Ideas

Quickly surfaces relevant payloads, bypasses, and one-liners based on context

Write Scripts Fast

Drafts working scripts, reformats output, and automates repetitive tasks

Recon & Enumeration

Summarises scan results, identifies patterns, suggests next steps

Report Writing

Drafts finding descriptions, rewrites technical jargon, speeds up documentation

AI = speed and breadth – not understanding

Quick Demo

• • • Terminal

\$ Prompt: find SQL injection

```
> ' OR 1=1--  
> ' UNION SELECT NULL--  
> '; DROP TABLE users--  
> admin'--  
> " OR ""="
```

→ Response: 200 OK

→ Time: 0.3s

Payloads generated instantly

Looks impressive

Feels like progress

Responses not validated

Context ignored

No manual confirmation

But... did we validate anything?

Where It Starts to Break



Hallucinated Vulnerabilities

AI confidently reports findings that don't exist. No CVE, no real path, no evidence.



Incorrect / Broken Payloads

Payloads that look right but don't work, or worse — break the target application.



Outdated Techniques

AI training data has a cutoff. Modern defences may already block what it suggests.



Misread Responses

AI can't see the actual HTTP response or system state. It guesses. Often wrongly.

AI sounds confident – even when it's completely wrong

The Dangerous Shift

AI lowers the barrier to doing things... but not to doing them well.

More Output

AI generates more ideas, more payloads, more text — faster than ever before.

Less Understanding

When AI does the thinking, your understanding of the underlying technique atrophies.

Higher Risk

More output + less understanding = a greater chance of putting wrong findings in a report.

The Auto-Pwn Mindset

What it looks like in practice:

- 1 Copy/paste payloads directly without testing them first
- 2 Trust AI explanations of vulnerabilities without verification
- 3 Skip building fundamentals because 'AI can explain it'
- 4 Chase speed over accuracy — more findings = better work
- 5 Can't explain how an exploit works, just that it 'should work'

Feels efficient. Yes???Not.

The Auto-Fail Reality

What actually happens on engagements:

False Positives in Reports

AI-suggested findings that don't exist. Client spends time investigating nothing.

Missed Real Vulnerabilities

AI focuses on pattern matching. Unusual or chained vulnerabilities get skipped entirely.

Broken Exploit Chains

Individual steps look right in isolation. The chain doesn't work because context was lost.

Loss of Client Trust

One wrong finding casts doubt on everything else. It's hard to recover from.

This is where careers take a hit.

The Credibility Problem

1 wrong finding

Doubt



Several wrong

Distrust



Blind AI usage

**Reputation
damage**

*You don't lose credibility because AI is wrong.
You lose it because you didn't catch it.*

AI in Reporting (Critical)

AI CAN

Write clean finding descriptions

Reword technical content accessibly

Structure findings consistently

Speed up the drafting process

BUT WILL

Remove important context from findings

Generalise risk (everything becomes Medium)

Miss actual business impact entirely

Sound authoritative while being wrong

Reports are your professional reputation. Don't outsource that.

Example: AI-Generated Finding

Finding: SQL Injection Vulnerability

MEDIUM

A SQL injection vulnerability was identified in the login functionality of the application. An attacker could potentially exploit this vulnerability to access, modify, or delete data within the database. It is recommended that parameterised queries or prepared statements are implemented to remediate this issue.

🚩 No exploitation evidence

🚩 No business context

🚩 Generic recommendation

Technically correct. Lacks urgency. No real-world context.
Would a CISO prioritise this? Probably not.

What Good Looks Like

The human layer that AI can't provide:

Finding: SQL Injection — Customer Database (Critical)

CRITICAL

Confirmed SQL injection in /api/login. During testing, we extracted 3 rows from the users table including admin credentials. Full database access is feasible without authentication. Given this application processes payments for 50,000 customers, a breach would trigger PCI DSS reporting obligations and potential regulatory action. Immediate patching is recommended before next release cycle.

Contextualised to the client environment

Clear impact with real-world evidence

Tied to regulatory/business risk

Actionable remediation timeline

AI drafts.
You decide what matters.

Where AI Fails in Engagements

Scope Nuance

AI doesn't know what's in or out of scope. It won't second-guess a target. You need to.

Weird Environments

Legacy systems, custom configs, unusual stacks — AI's training data doesn't cover edge cases.

Chained Attacks

Multi-step attack paths that combine minor flaws require human reasoning to piece together.

Client Conversations

Explaining risk, handling pushback, understanding business context — purely a human skill.

Pentesting is not just pattern matching.

The Key Insight

*AI can help you find things.
It cannot help you think critically about them.*

AI helps with:

Pattern-matched findings

Generated payload lists

Draft report content

Enumeration summaries

Humans provide:

Exploitation validity

Risk prioritisation

Business impact assessment

Attack chain reasoning

How to Use AI Properly

Treat AI like a capable but junior tester — useful input, not final authority.

USE AI TO

Brainstorm payload variations and attack approaches

Draft initial scripts and automate repetitive tasks

Rephrase findings for clarity or client audience

Summarise long scan output quickly

DON'T USE IT TO

Make final decisions on exploitability

Validate vulnerabilities on your behalf

Replace your understanding of a technique

Write your report without human review

Practical Workflow

Own your
enumeration

01

Do your own discovery first. Know the target before involving AI.

Use AI to expand
ideas

02

Bring AI in to broaden your thinking — not replace it.

Validate manually

03

Every AI suggestion gets tested by you. No exceptions.

Test edge cases

04

Re-run with variations. Check what AI missed or simplified.

05 → Then document — with your analysis, not AI's

AI fits in the middle — not the start or the end

Red Flags: Over-Relying on AI

- ❏ Saying "this looks right" instead of actually testing it
- ❏ Copy/pasting AI output directly into a client report
- ❏ Unable to explain how a finding works when asked
- ❏ Skipping manual verification because AI said it was confirmed
- ❏ Your understanding of techniques isn't growing — just your output

If you can't explain it, you don't own it.

What Makes You Valuable Now

Critical Thinking

The ability to reason about a finding, not just report it.
To ask 'so what?' and answer it.

Curiosity

Digging beyond the obvious. Exploring edge cases. Not stopping when AI says there's nothing.

Validation Discipline

The habit of verifying every finding manually. Every time.
Without exception.

Clear Communication

Translating technical findings into business risk. This is a human skill AI fundamentally lacks.

These are harder to automate. Build them deliberately.

The Future of Pentesting

What is certain:

AI tools will stay and improve

Automation will increase across all phases

The tool landscape will change rapidly

*The best testers won't be the fastest.
They'll be the most reliable.*

How to stay ahead:

Keep building manual skills alongside AI skills

Understand what the tools do, not just their output

Stay curious — the fundamentals still matter

The Final Message

*AI can help you move faster.
It can even make you look smarter.*

But it cannot replace your judgment.

*Auto-Pwn is easy.
Avoiding Auto-Fail is the real skill.*

Practical Takeaways

1

Always validate AI output — treat it as a starting point, not a conclusion

2

Never outsource your thinking — you own every finding on that report

3

Use AI to assist, not to decide — keep the judgment with the human

4

Focus on accuracy over speed — a clean 10 findings beats a noisy 50

5

Protect your credibility — it takes years to build and minutes to lose

Use AI.

Don't depend on it.

Dumisani Masimini | Pentest People

BSides Exeter



Dumisani Masimini
Penetration Tester



**Questions &
Discussion**